

Security Fundamentals

CCNA 200-301 V1.1

MODULE 8

Topics

8.1 Intro to Security

8.2 Local Device Access Control

8.3 Protecting Privileged EXEC Mode

8.4 Password Management

8.5 Local User

8.6 Password Recovery

8.7 Remote Access

8.8 Access Control List (ACL)

8.9 DHCP Snooping

8.10 Dynamic ARP Inspection (DAI)

8.11 Layer 2 Port Security

8.12 Authentication, Authorization and Accounting (AAA)

8.13 Wireless Security

8.14 Review



8.1 Intro to Security

CCNA 200-301 v1.1

Module 8

Essential Terminology

Implementing a Security Program

Essential Terminology

Term	Definition
Vulnerability	A weakness or flaw in a system
Threat	Anything that can potentially violate the security of a system or organization
Exploit	An actual mechanism for taking advantage of a vulnerability
Payload	The part of an exploit that actually damages the system or steals information
Compromise	Unauthorized access, control of, or damage to a computer system, network, or data
Zero-day attack	An attack that occurs before a vendor is aware of a flaw or is able to provide a patch for that flaw
Mitigation	Any administrative, physical or technical countermeasure to reduce the risk of compromise, or reduce the damage in case of compromise

Implementing a Security Program

A good security program should include the following components:

Information Security Policies

- Acceptable Use Policy, Password Policy, Remote Access Policy, Access Control Policy, etc.

Data protection and privacy

Physical security

Security baselines

- Minimum standards for different device, application, and data types

Access control and identity management

Network security

- Security zones, firewalls, IDS/IPS, VPNs, network segmentation (VLANs)



Implementing a Security Program (cont'd)

Endpoint security

Vulnerability management

- Patching and updates

Logging, monitoring, auditing

Third-party vendor management

End-user training and awareness

Incident response (disaster recovery, business continuity)



8.2 Local Device Access Control

CCNA 200-301 v1.1

Module 8

Local Device Security Best Practices

Banners

Local Authentication

Auto Secure

Local Device Security Best Practices

Create an enable secret

Require users to authenticate

Prefer centralized authentication with AAA and MFA over local passwords

Require authentication for console and VTY access

Prefer SSH instead of telnet

Disable unused services and ports such as HTTP or SNMP



Local Device Security (cont'd)

Consider using the auto security command to assist with device security configuration

Create banner messages for legal notices

Regularly audit logs

- Configure syslog to monitor for unauthorized access
- Use AAA to track access

Consider disabling password recovery to prevent unauthorized physical access to the device

Provide physical security

Encrypt and securely store device backups



Banners



Login Banners

A banner is a message displayed to users when they log in to a Cisco device

Can be used to display legal warnings, notices, or information to users

Banners can be:

- Message of the day (MOTD) banner
 - The user will see this message after they have logged in
- Login banner
 - The user will see this message before they log in
- Exec banner
 - The user will see this message as they attempt to enter privileged mode

Create the banner in global configuration mode

- Indicate a delimiter such as **x** or **^C** to mark the start and end of the banner text



Message of the day (MOTD) Examples

```
R1(config)# banner motd #
```

```
Building power will be off from 7:00 AM until 9:00 AM this  
coming Tuesday.
```

```
#
```



Login Banner Example

```
Router(config)# banner login ^C
```

```
*****
```

```
WARNING: Unauthorized access to this device is prohibited.
```

```
All activities will be monitored and reported.
```

```
*****
```

```
^C
```



EXEC Banner

```
Router(config)# banner exec ^
```

```
Authorized personnel only. Proceed with caution.^
```



Banner Commands

Command	Description
<code>[no]banner login</code> <code><delimiter><message><delimiter></code>	Create (or delete) a message users will see as they first log on to the device
<code>[no]banner motd</code> <code><delimiter><message><delimiter></code>	Create (or delete) an informational message of the day that users will see after they have logged into the device
<code>banner exec</code> <code><delimiter><message><delimiter></code>	Create (or delete) a message users will see when they attempt to enter privileged mode
<code>show running-config include banner</code>	View the current running configuration, showing only banner configurations



Local Authentication



Local Authentication

Users are authenticated against the device itself

Username and password are stored in the running / startup configuration file(s)

Local authentication does not forward authentication to a AAA server



Configuring Local Authentication

You can specify that all users are authenticated against the local device

1. Create the user account (with privilege level and password)
2. Specify the connection type that requires authentication:
 - Console
 - VTY
3. Specify login local

```
R1(config)# line console 0
```

```
R1(config-line)# login local
```

```
R1(config)# line vty 0 15
```

```
R1(config-line)# login local
```



Auto Secure



Auto Secure

A wizard that automates security best practices on the router

At the interactive prompt, you indicate your security requirements

It will implement your requirements including:

- Disable unnecessary services (e.g., finger, HTTP, CDP)
- Enforce password security and encryption
- Configure SSH for remote management (disables Telnet)
- Enable AAA (optional)
- Enable logging and source routing protection
- Configure Unicast Reverse Path Forwarding (uRPF)
 - Helps prevent IP address spoofing
 - Ensures that packets received on an interface have a valid return path (known route back to the source)
- Configure ACLs for basic packet filtering (optional)

```
Router# auto secure
```



Auto Secure Commands

Command	Description
<code>auto secure</code>	Launch the auto secure wizard Answer the prompts

Note: You cannot issue a “no auto secure” command to undo all of the security auto secure has implemented. You will have to manually disable the various security settings yourself.

Securing the Enable Command

8.3 Protecting Privileged EXEC Mode

CCNA 200-301 v1.1

Module 8

Securing the Enable Command

Used to move from USER EXEC unprivileged mode (Privilege Level 1) to PRIVILEGED EXEC mode (Privilege Level 15)

- You can enter privileged EXEC just by entering the **enable** command
- For security, you should put a password on the **enable** command
- Once in privileged mode, the user can perform any action on the device

By default does not require a password

You should set a secret on the enable command



Configuring the Enable Password

```
R1(config)# enable password [0] <password>
```

- If service password-encryption is not set, will store enable password in clear text

```
R1(config)# enable password [0|7] <password>
```

- If service password-encryption IS set, will store the enable password using Type 7 encryption
- If 0 or no number is specified, an unencrypted password will follow (encrypt and store as Type 7)
- If 7 is specified, a Cisco 7 encrypted version of the password will follow (store as entered)

```
R1(config)# enable secret [0|5] <password>
```

- Store the password as an MD5 hash (regardless if service password-encryption is set or not)
- If 0 or no number is specified, an unencrypted password will follow (perform MD5 hash and store hashed)
- If 5 is specified, an MD5 (with salt) hashed version of the password will follow (store as entered)

If both enable password and enable secret are set, the user will be required to enter the enable secret

8.4 Password Management

CCNA 200-301 v1.1

Module 8

Password Management

Password Policy

Password Alternatives

Cisco Password Management

You can implement strong password policies

- Enforce minimum password length and complexity with `security passwords`
- Avoid common words; don't use dictionary words or easily guessable passwords like "cisco123" or "password"

Avoid weak Type 7 password encryption

- `service password-encryption` encrypts passwords in config files with Type 7

Use stronger hashes like Type 5 (MD5) or Type 9 (scrypt) where available

- For MD5: `enable secret <strong_password>`
- For scrypt: `enable algorithm-type scrypt secret <strong_password>`

Implement Multi-factor Authentication (MFA) for extra security

- Integrate devices with TACACS+ or RADIUS for MFA



Password Policy

Depending on the make and model, you can set a variety of password policy options on Cisco devices:

- Complexity, length, history, aging and more

IOS password options:

```
R1(config)# security passwords complexity enable
```

- Mix of upper and lower case, number(s), special character(s)

```
R1(config)# security passwords min-length [length]
```

- Minimum number of characters
- Default is 8

```
R1(config)# security passwords history [number]
```

- Must cycle through this many passwords before reusing a previous password

```
R1(config)# security passwords aging [days]
```

- Maximum number of days before a password must be changed

```
R1(config)# security passwords unprivileged-mode
```

- Applies password policies even to non-privileged users



Password Alternatives

Multi-factor authentication (MFA) uses 2 or more “factors” to authenticate a person:

- Something you know
 - Password / PIN
- Something you have
 - Certificate
 - Smart card
 - Token
- Something you are
 - Biometrics
- One-time passcode sent to email or phone
 - Usually considered to be something you have

You typically enable MFA on a Cisco device by integrating it with an authentication server

- Cisco ISE, Duo Security, AAA server (RADIUS, TACACS+)



Local User Account

Password Encryption Levels

8.5 Local User

CCNA 200-301 v1.1

Module 8

Local User Account

Create a username and password on the device you are connecting to

Specify privilege level 1, 15, or custom (2 – 14)

- If you do not specify the privilege level, the user is saved as an unprivileged user 1
 - They must enter the enable password to enter privileged mode
- If you specify privilege level 15 for the account, when they connect they automatically enter in privileged mode
 - They do not need to enter the enable password

Local usernames and passwords are stored in running / startup configuration

```
R1(config)# user <name> [ privilege <level>] [ password | secret ] [ 0 | 5 | 7 ] <password>
```

Clear
text

MD5
hash

Type 7
encryption

```
R1 (config) # user admin privilege 15 secret letmein
```



Password Encryption Levels

Store password as clear text

- Use keyword “password” or “password 0” followed by password
- Only stores as clear text if **service password-encryption** is not set

Type 7 encryption

- Will encrypt and store the password using Cisco 7 encryption – easily cracked
- Use keyword “password” followed by 0 or 7
- 0 = An unencrypted version of the password will follow
- 7 = A Cisco 7 encrypted version of the password will follow – will store the encrypted password as entered

MD5 hash

- Will store the password as an MD5 hash with 32-bit salt
- Use keyword “secret” followed by 0 or 5
- 0 = An unencrypted version of the password will follow
- 5 = An MD5 hash (with salt) of the password will follow – will store the hash as entered

If you enter the global command **service password-encryption**, all current and future clear text passwords are encrypted using Cisco 7 encryption

- Will not affect secret passwords stored as MD5 hash



No Password Example

```
R1(config)# user moo
```

- Unprivileged user with no password
- User logs in simply by entering username with no password

```
R1(config)# user belvie privilege 15
```

- Privileged user with no password
- User automatically enters in privileged mode



**Creating accounts
with no password
is a bad idea!**



Clear Text Password Examples

If **service password-encryption** is not set, stores the password in clear text:

```
R1(config)# user jaja password letmein
```

```
R1(config)# user jaja password 0 letmein
```



Type 7 Encrypted Passwords

R1(config)# user daisy password 0 letmein

- Expects an unencrypted password to follow
- If **service password-encryption** is set, will store the password as Type 7 encrypted

R1(config)# user lily password 7 020A014F0603062F

- Expects a Cisco 7 encrypted password to follow
- Will store the encrypted password as entered

R1(config)# service password-encryption

- Encrypts all current and future clear-text passwords (user, enable, etc.)
- Uses Type 7 encryption
- Does not change any passwords stored as an MD5 hash



Type 5 (MD5) Hashed Passwords

```
R1(config)# user chrys secret 0 letmein
```

- Expects an unencrypted password to follow
- Will always store the password as a salted md5 hash, even if **service password-encryption** is set

```
R1(config)# user admin secret 5
```

- Will store the password as entered (MD5 hash with salt)

\$1\$mERr\$uOMJQ2KifpDVhgshEPjVU/

md5 salt hashed password



Type 9 (scrypt) Hashed Passwords

Requires significant memory resources to compute the hash

- Considerably more resistant to brute-force attacks
- Currently the most secure option on Cisco devices for password encryption

Not supported on older Cisco devices

```
enable algorithm-type scrypt secret <strong_password>
```

```
username <user> algorithm-type scrypt secret <strong_password>
```



Password Commands

Command	Description
<code>enable password [0 7] <password></code>	Create a Type 7 enable password 0 = unencrypted password will follow 7 = encrypted password will follow
<code>enable secret [0 5] <password></code>	Create a Type 5 MD5 hashed enable password 0 = unencrypted password will follow 5 = encrypted password will follow
<code>service password-encryption</code>	Encrypt all current and future clear text passwords with Type 7 encryption
<code>User <name> privilege <level> password secret <password></code>	Create a user with privilege level and Type 7 or Type 5 password
<code>line console 0</code>	Enter line (console) configuration mode
<code>line vty 0 15</code>	Enter VTY (telnet, SSH) configuration mode
<code>login local</code>	Require the user to log in when connecting

Cisco Password Recovery

8.6 Password Recovery

CCNA 200-301 v1.1

Module 8

Cisco Password Recovery

Used when privileged passwords to the device have been forgotten or lost

Requires physical access to the device

You boot the device into ROMMON mode and temporarily change the configuration register

Can be disabled with the global command `no service password-recovery`



Password Recovery Steps

1. Connect to the device via a console (rollover) cable
2. On your PC, launch a terminal emulator such as PuTTY
3. On the terminal emulator, open a serial connection with the following settings:
 - Baud rate: 9600
 - Data bits: 8
 - Parity: none
 - Stop bits: 1
 - Flow control: none
4. Turn the device off and back on
5. As the router starts to boot, press Ctrl+Break to enter ROMMON mode



Password Recovery Steps (cont'd)

6. Change the configuration register to 0x2142 to tell the device to ignore startup-config
`confreg 0x2142`
7. Reboot the device
`reset`
8. After the device boots, load startup config into running config
9. Change the password
10. Save running config back to startup config
11. Change the configuration register back to 0x2102
`confreg 0x2102`
12. Save running config again to startup config
13. Restart the device and log in normally



Password Recovery Commands

Issue these commands in ROMMON mode:

Command	Description
<code>confreg 0x2142</code>	Ignore startup-config on bootup
<code>reset</code>	Reboot
<code>confreg 0x2102</code>	Apply startup-config on bootup

Issue this command after booting normally:

Command	Description
<code>show version</code>	Displays hardware and software information about the device including the current configuration register

8.7 Remote Access

CCNA 200-301 v1.1

Module 8

What is Remote Access?

IPSEC

Site-to-Site VPN

What is Remote Access?

The ability to access a system or network, whether it's a personal device or office server, without being physically present

Allows employees to work off-site, such as at home or in another location

- Maintains secure access to a distant computer or network

Typically accomplished through a VPN connection



IP Security (IPSEC)

The most common type of VPN

Used for:

- Remote Access
- Site-to-site VPNs

Consists of two protocols:

- Authentication Header (AH) – Protocol ID 51
- Encapsulating Security Payload (ESP) – Protocol ID 50

You can use one or both of these protocols as desired

- Most implementations just use ESP

Has two modes:

- Tunnel
- Transport

Uses ISAKMP and IKE to negotiate the session

- Securely exchange public keys
- Agree on how traffic will be encrypted and decrypted



Authentication Header (AH)

Protocol ID 51

Validates the integrity and authenticity of the packet

- Calculates an HMAC hash over the payload and (most of the) IP header
- HMAC-SHA-512 / 384 / 256, HMAC-SHA-1 (legacy), HMAC-MD5 (legacy)

Does not encrypt the payload

Cannot tolerate network address translation (NAT)

- Translation of the Layer 3 header breaks the hash

When used with ESP, adds an extra layer of security



Encapsulating Security Payload (ESP)

Protocol ID 50

Encrypts the payload

Calculates an HMAC hash over the TCP or UDP header and data

Does not modify the Layer 3 header

Used to protect the confidentiality and integrity of the payload

- Most common implementation of site-to-site IPSEC VPNs

By itself does not tolerate network address translation (NAT)

NAT Traversal (NAT/T) is a variant of ESP that can tolerate NAT

- The entire ESP packet is encapsulated in a UDP datagram
- As a payload of UDP, it is unaffected by any NAT changes applied to the Layer 3 or Layer 4 header



ISAKMP and IKE

Used by IPSEC to form a VPN between two peer devices

- Routers, firewalls, VPN servers, hosts, etc.

Internet Security Association and Key Management Protocol (ISAKMP)

- A framework for creating *Security Associations* (SAs) between routers
- SAs define the policy and cryptographic parameters for communicating over IPSEC
- You must have two SAs, one in each direction, between the devices

Internet Key Exchange (IKE)

- A protocol that uses ISAKMP to negotiate and establish secure communications
- Uses the Diffie-Hellman algorithm for exchanging keys and negotiating cryptographic parameters



IPSEC Transport Mode

Used to create host-to-host VPNs

Packets are not encapsulated inside another IP packet

Two hosts create a VPN directly between them

Hosts have to be able to route traffic to each other

Typically used for client-server or server-server connections

- Extra security between hosts in a private network
 - Server-to-server replication
- Secure connection between hosts in different security zones
 - Web server front end in DMZ to database server back end in private network
- Client-to-server connection across the Internet



IPSEC Tunnel Mode

Used to create site-to-Site VPNs

Packets ARE encapsulated inside another IP packet

- Often a private IP packet hidden inside a public IP packet

Two edge devices (routers, firewalls) create a VPN between them

- Typically over the Internet

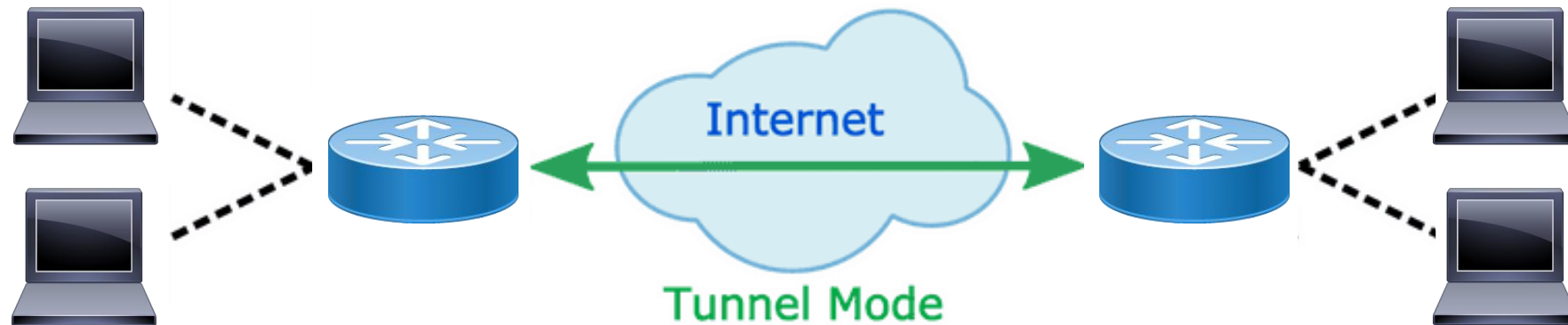
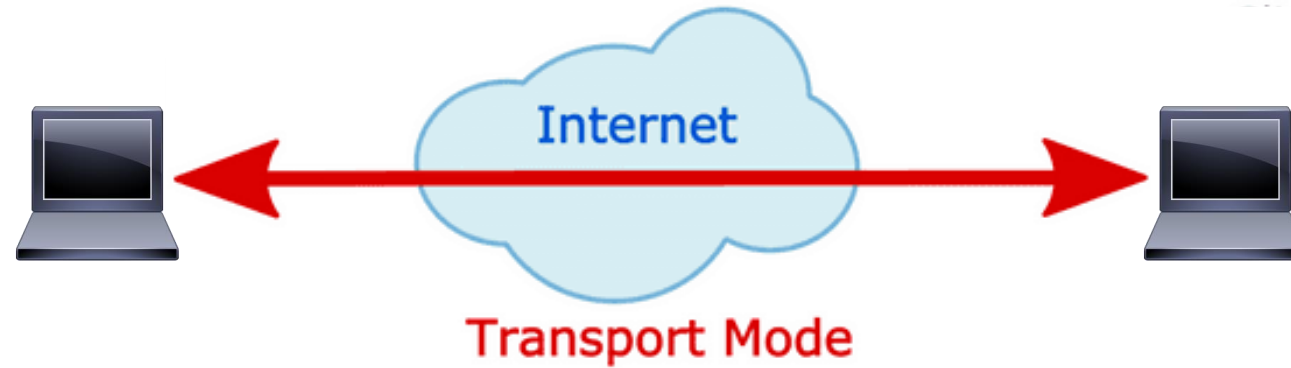
Client traffic between the two networks flows through the VPN

- Client traffic is only encrypted when in the tunnel
- Clients are unaware that the connection is a VPN

Allows subnets with private IP addresses to connect to each other

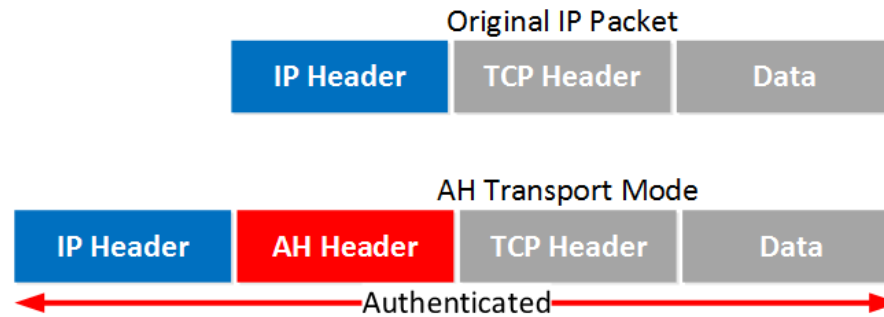


IPSEC Modes Example

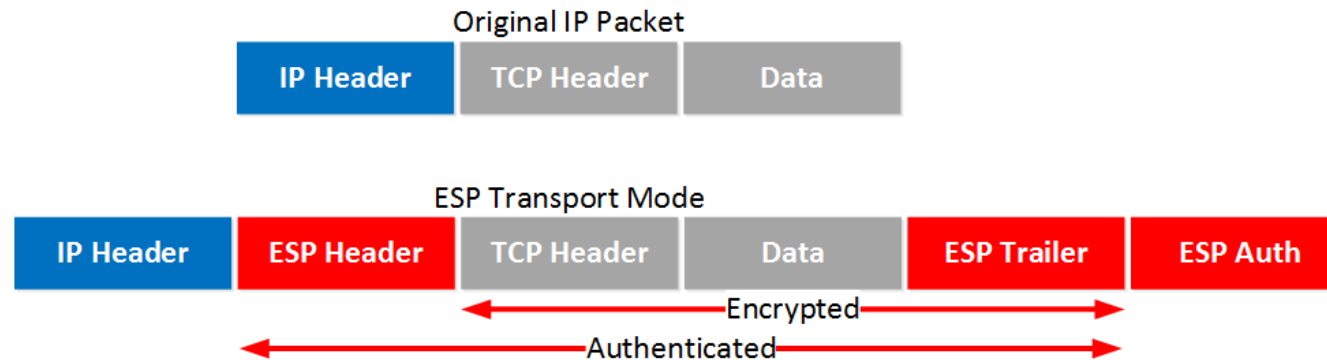


IPSEC Transport Mode Packet Structure

AH

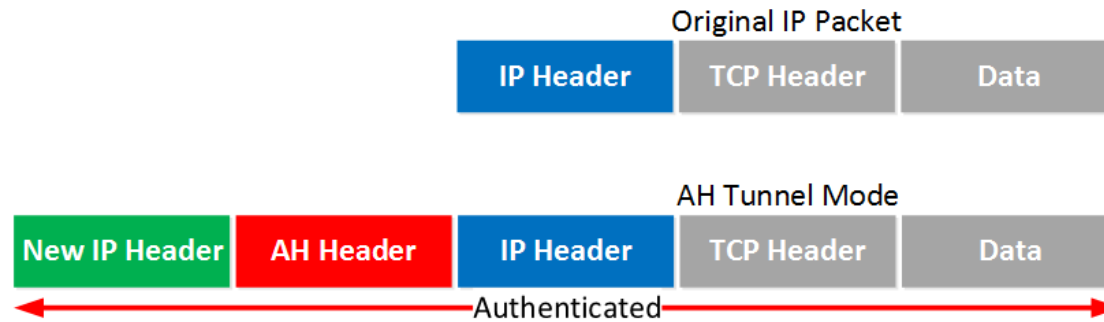


ESP

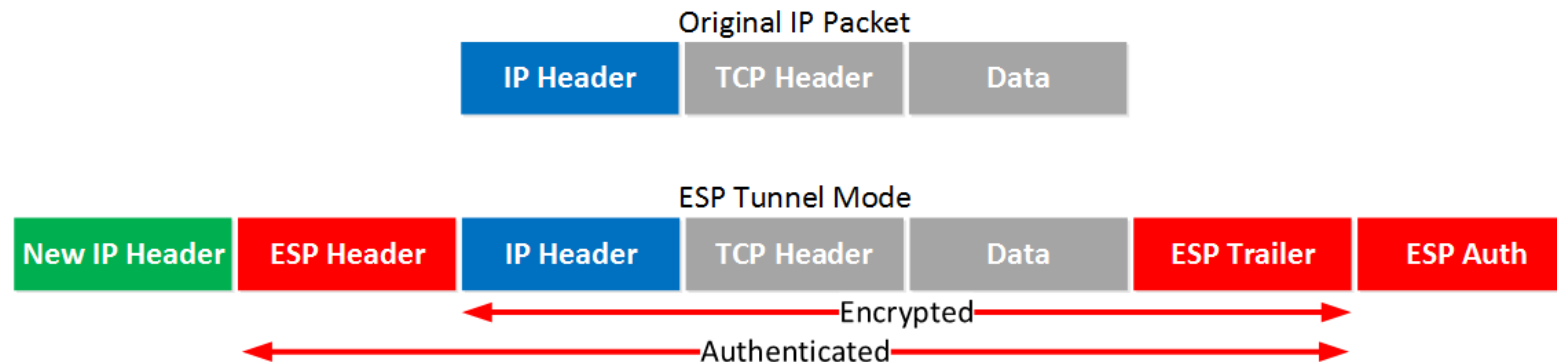


IPSEC Tunnel Mode Packet Structure

AH



ESP



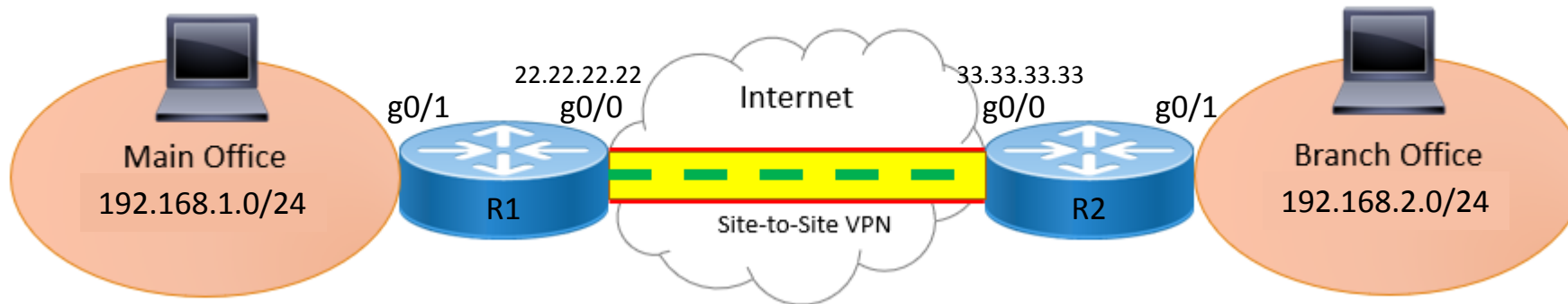
Site-to-Site VPN

Typically implemented as IPSEC Tunnel Mode

- ESP, with or without AH

Both sites can use private IP addresses

- Can't have any overlap
- You should create static routes on the routers
 - Point to the other router's tunnel endpoint (public IP address) as the next hop



```
R1(config)# ip route 192.168.2.0 255.255.255.0 33.33.33.33
```

```
R2(config)# ip route 192.168.1.0 255.255.255.0 22.22.22.22
```



Configuring a Site-to-Site VPN

1. Configure ISAKMP Phase 1 parameters
2. Set the pre-shared key
3. Configure IPsec Phase 2
4. Create an Access Control List (ACL) to define interesting traffic
5. Configure the Crypto Map
6. Apply the Crypto Map to the WAN interface
7. Configure complementary settings on the other site router
8. Save, verify and test



Site-to-Site IPSEC VPN Example

1. Configure ISAKMP Phase 1 parameters

Create policy “10”, encrypt with AES256, hash with SHA-256, use a pre-shared key, use Diffie-Hellman 2048-bit key exchange, set the IKE SA lifetime to 1 day (86400 seconds)

- `R1(config)# crypto isakmp policy 10`
- `R1(config-isakmp)# encryption aes 256`
- `R1(config-isakmp)# hash sha256`
- `R1(config-isakmp)# authentication pre-share`
- `R1(config-isakmp)# group 14`
- `R1(config-isakmp)# lifetime 86400`



Site-to-Site IPSEC VPN Example (cont'd)

2. Set the pre-shared key, indicating the peer address:

- `R1(config)# crypto isakmp key MySecretKey address <peer public address>`

3. Configure IKE Phase 2 (IPSEC Transform Set):

- `R1(config)# crypto ipsec transform-set MY_TRANSFORM_SET esp-aes esp-sha-hmac mode tunnel`

4. Create an Access Control List (ACL) to define interesting traffic:

```
R1(config)# access-list 100 permit ip 192.168.1.0 0.0.0.255 192.168.2.0 0.0.0.255
```

5. Configure the Crypto Map

- `R1(config)# crypto map VPN_MAP 10 ipsec-isakmp`
- `R1(config-crypto-map)# set peer 33.33.33.33`
- `R1(config-crypto-map)# set transform-set MY_TRANSFORM_SET`
- `R1(config-crypto-map)# match address 100`



Site-to-Site IPSEC VPN Example (cont'd)

6. Apply the Crypto Map to the WAN interface

- `R1(config)# interface GigabitEthernet0/0`
- `R1(config-if)# ip address 22.22.22.22 255.255.255.0`
- `R1(config-if)# crypto map VPN_MAP`
- `R1(config-if)# no shut`

7. Save, verify and test

- `R1(config-if)# end`
- `R1# copy running-config startup-config`
- `R1# show crypto isakmp sa //Check phase 1 status`
- `R1# show crypto ipsec sa //Check phase 2 status`
- `R1# ping 192.168.2.20`



IPSEC Commands

Command	Description
<code>crypto isakmp policy <number></code> <code>crypto isakmp policy 10</code>	Create an IPSEC policy
<code>encryption <algorithm> <strength></code> <code>encryption aes 256</code>	Declare the encryption algorithm and strength
<code>hash <hashing algorithm></code> <code>hash sha256</code>	Declare the hashing algorithm
<code>authentication pre-share</code>	Indicate that the IPSEC peers will authenticate via pre-shared key
<code>group <Diffie-Hellman group></code> <code>group 14</code>	Indicate the key exchange strength
<code>lifetime <seconds></code> <code>lifetime 86400</code>	Indicate the lifetime of the security association (SA)



IPSEC Commands (cont'd)

Command	Description
<pre>crypto isakmp key <key> address <peer public address></pre>	Set the pre-shared key, indicating the peer public address
<pre>crypto isakmp key MySecretKey address 33.33.33.33</pre>	
<pre>crypto ipsec transform-set <name> <encryption> <hash> mode <type></pre> <pre>crypto ipsec transform-set MY_TRANSFORM_SET esp-aes esp-sha- hmac mode tunnel</pre>	Configure IKE Phase 2 (IPSEC Transform Set)
<pre>access-list 100 permit ip <subnet for peer 1> <wildcard mask> <subnet foir peer 2> <wildcard mask></pre>	Create an ACL specifying interesting traffic (all IP traffic going from subnet 1 to subnet 2)



IPSEC Commands (cont'd)

Command	Description
<code>crypto map <name> <sequence number> ipsec-isakmp</code>	Globally enable the VPN map
<code>crypto map VPN_MAP 10 ipsec-isakmp</code>	
<code>set peer <peer public IP address> set peer 33.33.33.33</code>	Declare the VPN peer public IP address
<code>set transform-set <name> set transform-set MY_TRANSFORM_SET</code>	Indicate which transform set the map will use
<code>match address <access-list #> match address 100</code>	Indicate which access-list will be used to specify interesting traffic



IPSEC Commands (cont'd)

Command	Description
<code>crypto map <name></code> <code>crypto map VPN_MAP</code>	Apply the crypto map on the public interface
<code>show crypto isakmp sa</code>	Check phase 1 status
<code>show crypto ipsec sa</code>	Check phase 2 status
<code>ping <IP in peer network></code>	Test the VPN with a ping

8.8 Access Control List (ACL)

CCNA 200-301 v1.1

Module 8

What is an ACL?

Standard ACL

Source and Destination

Extended ACL

Named ACL

Order of ACL Rules

Implicit Deny All

Applying an ACL

ACL Best Practices and Troubleshooting

Common Protocols and Ports

What is an ACL?

A set of rules used to control traffic in and out of a firewall, router, or multilayer switch

Can be used for:

- packet filtering, defining a range of source addresses for NAT, defining interesting traffic for a VPN, QoS traffic prioritization, controlling access to VTY lines (Telnet/SSH Access), and more

Each packet is compared to the rules in the ACL and processed accordingly

Rules typically include:

- Name
- Action
- Protocol
- Source IP address
- Destination IP address
- Source port
- Destination port

All ACLs have an implicit “deny all” at the end

- If you configure only deny rules, you need to add a “permit” rule at the end to allow some traffic



Standard ACL

Filters traffic based on source IP address only

Typically applied near the destination to avoid unintended filtering of traffic

Uses numbers between 1-99 (and expanded range 1300-1999)

One ACL can have many rules

- Rules are evaluated in order from top to bottom
- If you add more rules to the same ACL, they are appended to the bottom of the list
- There is always an implicit deny all at the very end of any ACL
- Once the ACL is created, the rule order cannot be rearranged
- Best practice is to pre-create the ACL in a text editor first, then copy and paste all statements together in the console

```
access-list <number> {permit|deny} <source> [wildcard mask]
```



Source and Destination

Specify a range of hosts:

- `192.168.1.0 0.0.0.255`

Specify any host:

- `0.0.0.0 255.255.255.255`
- `any`

Specify a single host:

- `<host IP> 0.0.0.0`
- `host 192.168.1.1`

Examples:

- `access-list 1 permit 172.16.0.0 0.0.255.255`
- `access-list 1 deny host 192.168.1.1`
- `access-list 1 deny 192.168.1.2 0.0.0.0`
- `access-list 1 permit 0.0.0.0 255.255.255.255`
- `access-list 1 permit any`



Standard ACL Examples

```
R1(config)# access-list 10 permit host 192.168.1.100
```

```
R1(config)# access-list 10 deny 192.168.1.0 0.0.0.255
```

```
R1(config)# access-list 10 permit any
```



Extended ACL

Filters traffic based on multiple criteria:

- Protocol type (IP, TCP, UDP, ICMP, etc.)
- Source and destination IP addresses
- Source and destination port
 - For common ports, you can specify the Layer 7 protocol instead
- Other parameters (such as TCP flags, ICMP types)

Typically applied near the source

Uses numbers from:

- 100-199 (Standard extended ACL number range)
- 2000-2699 (Expanded extended ACL number range)



Extended ACL (cont'd)

Operator can be:

- eq: Equal to (match a specific port)
- lt: Less than
- gt: Greater than
- range: A range of port numbers

```
access-list <number> {permit|deny} <protocol> <source> <source-wildcard>  
<destination> <destination-wildcard> [operator <port>]
```



Extended ACL Examples

```
access-list 101 permit tcp any 192.168.1.1 0.0.0.0 eq 80
access-list 101 permit ip host 192.168.1.200 any
access-list 101 deny tcp 192.168.1.0 0.0.0.255 any eq telnet
access-list 101 deny tcp 192.168.1.0 0.0.0.255 eq 4444 any
access-list 101 deny icmp any any
access-list 101 permit ip any any
```



Named ACL

You can give either a standard or extended ACL a name in place of a number

If you create a named ACL, create the ACL first then add rules

```
ip access-list standard|extended <name>
```

```
Router(config)# ip access-list standard MY_ACL
```

```
Router(config-std-nacl)# permit 192.168.1.0 0.0.0.255
```

```
Router(config-std-nacl)# exit
```

```
Router(config)# ip access-list extended MY_EXTENDED_ACL
```

```
Router(config-ext-nacl)# permit tcp 192.168.1.0 0.0.0.255 any eq 80
```

```
Router(config-ext-nacl)# exit
```



Order of ACL Rules

ACL rules are read from the top down

- Each packet is evaluated against the rule set

If a match is found at a rule, the specified permit or deny is applied

- No other rules are checked
- The packet is through being evaluated

At the end of any ACL is an implicit “deny all” statement

An ACL’s rule order cannot be changed without re-creating the entire ACL



Implicit Deny All

At the end of any ACL is an implicit “deny all” statement

If you configure only deny rules, you need to have some type of “permit” rule at the end to allow some traffic

What is the end result of this example:

```
access-list 102 deny tcp any host 1.1.1.1 eq 23
```

```
access-list 102 deny icmp any any
```

```
access-list 102 deny tcp any any eq 3389
```

No traffic of any type will be allowed pass through!

Add `permit ip any any` at the end to allow allow all other traffic to pass



Applying an ACL

Once an ACL is created, you can choose to apply it to an interface

You can only apply one ACL per direction (in|out) per interface

```
R1(config)# int g0/0
```

```
R1(config-if)# ip access-group 101 in
```

```
R1(config)# int g0/1
```

```
R1(config-if)# ip access-group 1 out
```



ACL Best Practices

Create a diagram showing parts of the network that would be affected by the ACL including:

- IP addresses, routers and firewalls, services, access-list rules, interfaces, ACL direction
- Draw arrows showing traffic flow
- Your diagram should contain all information necessary to perform any troubleshooting

Create your ACL in a text editor first before copying its rules to the command line

Map ACL statements to desired traffic flows for correct implementation

When looking at the rules order, ensure that no rule higher in the ACL adversely affects the desired outcome of a rule lower in the list

- As a general rule, place the more specific rules toward the top of the list

Always keep in mind that any ACLs will end with an implicit deny all



Troubleshooting an ACL

Using your ACL network diagram as a reference, send test traffic through the path to see if the outcome is as expected

Append the keyword `log` to the ACL statement in question

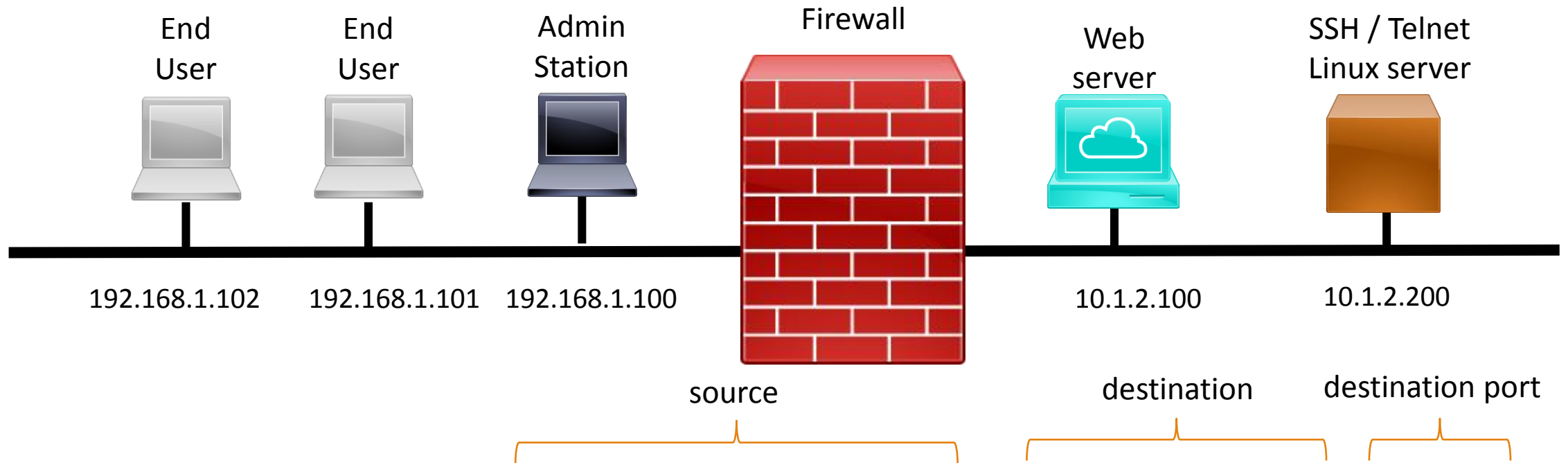
- Send test traffic then view the log
- Not available on all devices
- `access-list 102 deny tcp any host 1.1.1.1 eq 23 log`

Use an IP packet filter in a debug command

- Resource intensive
- `debug ip packet detail <source or destination IP you are interested in>`
- `u all`



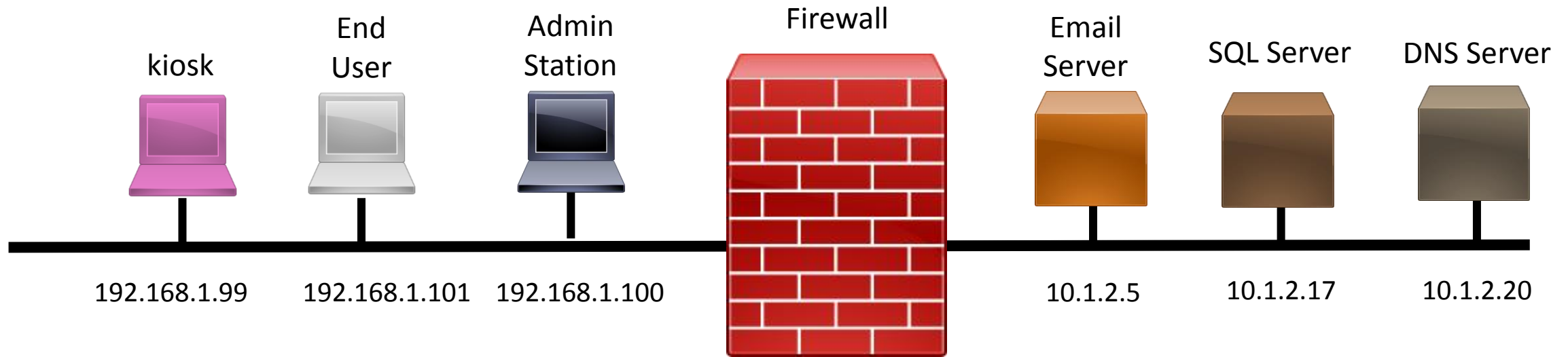
ACL Example



```
access-list 101 deny tcp any eq 4444 any
access-list 101 deny tcp any
access-list 101 permit tcp 192.168.1.0 0.0.0.255 host 10.1.2.100 eq http
access-list 101 permit tcp host 192.168.1.100 host 10.1.2.200 eq ssh
access-list 101 permit ip 0.0.0.0 255.255.255.255 any
```



ACL Example #2



				source	destination	destination port
access-list 101	permit	udp		any	host 10.1.2.20	eq 53
access-list 101	permit	tcp		192.168.1.0 0.0.0.255	host 10.1.2.5	eq 25
access-list 101	permit	tcp		host 192.168.1.100	host 10.1.2.17	eq smb
access-list 101	deny	icmp		192.168.1.101 0.0.0.0	any	
access-list 101	deny	ip		host 192.168.1.99	any	
access-list 101	permit	ip		any	any	



Common Protocols and Ports

Port	Protocol	Name	Description	Encrypted
20/21	TCP	FTP	File Transfer Protocol data, commands	No
22	TCP	SSH	Secure Shell – for text-based remote administration	Yes
23	TCP	telnet	For text-based remote administration, replaced by SSH	No
25	TCP	SMTP	Simple Mail Transfer Protocol; for sending email	No
49	TCP	TACACS+	TACACS+ server / client communications	Yes
53	UDP, TCP	DNS	For querying a DNS server; TCP used for server replication	No
67/68	UDP	DHCP	DHCP client and server ports	No
69	UDP	TFTP	Trivial FTP; for simple, unauthenticated file transfer	No
80	TCP	HTTP	Hypertext Transfer Protocol, for web traffic	No



Common Protocols and Ports (cont'd)

Port	Protocol	Name	Description	Encrypted
88	TCP	Kerberos	For Active Directory authentication	Yes
110	TCP	POP3	Post Office Protocol	No
111	TCP, UDP	RPC	UNIX/Linux portmapper service	No
119	TCP	NNTP	Network News Transfer Protocol	No
123	UDP	NTP	Network Time Protocol	No
135	TCP	RPC	Microsoft port mapper service	Depends
139	TCP	SMB v1	Server Message Block; Microsoft file and print protocol	No
143	TCP	IMAP4	Internet Messaging Access Protocol	No
161, 162	UDP	SNMP	Simple Network Management Protocol	No



Common Protocols and Ports (cont'd)

Port	Protocol	Name	Description	Encrypted
389	TCP	LDAP/LDAPS	Lightweight Directory Access Protocol	No/Yes
636	TCP	LDAPS	Lightweight Directory Access Protocol Secure	
443	TCP	HTTPS	HTTP Secure; for SSL or TLS encrypted HTTP	Yes
445	TCP	SMB v2, v3	Windows login, file and print services	v3.0
500	UDP	IKE	Internet Key Exchange, for negotiating an IPSEC VPN	No
514	UDP	syslog	For forwarding log messages to a central syslog server	No
587	TPC	SMTP	Encrypted SMTP	Yes
993	TCP	IMAP over SSL	Encrypted IMAP	Yes
995	TCP	POP3 over SSL	Encrypted POP3	Yes



Common Protocols and Ports (cont'd)

Port	Protocol	Name	Description	Encrypted
1433	TCP	MSSQL	Microsoft SQL server	No
1521	TCP	Oracle SQL	Oracle SQL server	Depends
1723	TCP	PPTP	Point-to-Point Tunneling Protocol; early Microsoft VPN	Payload
1812	UDP	RADIUS	RADIUS server / client communications	No
3306	TCP	MySQL	MySQL database server	No
3389	TCP	RDP	Remote Desktop Protocol	Payload
5060/5061	TCP, UDP	SIP	Session Initiation Protocol; establish + manage VoIP calls	No, Yes



ACL Commands

Command	Description
<pre>access-list [number type <name>] [permit deny] <source> [wildcard mask]</pre> <pre>access-list 10 permit host 192.168.1.100</pre>	Create a standard ACL
<pre>access-list [number type <name>] [permit deny] <protocol> <source> <source-wildcard> [operator <port>] <destination> <destination-wildcard> [operator <port>]</pre> <pre>access-list 100 deny tcp any host 192.168.1.200 eq 80</pre>	Create an extended ACL
<pre>ip access-group 10 [in out]</pre>	Apply ACL on the interface



ACL Verification Commands

Command	Description
<code>show access-lists</code>	Provide details of all access lists
<code>show access-lists <number name></code> <code>show access-lists sales</code> <code>show access-lists 20</code>	Provide details of a specific access list
<code>show ip access-lists</code>	Provide details of IP access lists
<code>show ip access-lists <number name></code> <code>show ip access-lists sales</code> <code>show ip access-lists 20</code>	Provide details of a specific IP access list
<code>show ip interface <type><number></code> <code>show ip interface g0/0</code>	Show IP details of an interface, including ACL and direction
<code>show running-config include access-list</code>	Show current running configuration, only include lines starting with “access-list”

8.9 DHCP Snooping

CCNA 200-301 v1.1

Module 8

What is DHCP Snooping?

DHCP Snooping Components

Configuring DHCP Snooping

What is DHCP Snooping?

A security feature in network switches

Helps to prevent malicious or rogue DHCP servers from providing incorrect IP address information to clients within the network

Works by creating a database of IP addresses that have been assigned by the legitimate DHCP server

- Blocks any DHCP responses from unauthorized or rogue servers
- Blocks traffic of any device that spoofed its IP or did not receive a lease from a legitimate DHCP server



DHCP Snooping Components

Trusted Ports

- Ports on the switch where legitimate DHCP servers are connected are marked as "trusted"

Untrusted Ports

- All other ports, typically where client devices connect, are marked as "untrusted"

DHCP Binding Table

- The switch maintains a binding table, which records the MAC address, IP address, lease time, binding type, and VLAN information of each device that receives an IP address from the legitimate DHCP server

Packet Inspection

- The switch inspects all DHCP packets that pass through untrusted ports
- If a DHCP Offer or DHCP Acknowledgment packet is detected on an untrusted port, the switch drops the packet if it doesn't come from a trusted source



Configuring DHCP Snooping

Enable DHCP snooping globally

- `Switch(config)# ip dhcp snooping`

Enable DHCP snooping on a specific VLAN

- `Switch(config)# ip dhcp snooping vlan <vlan-id>`

Mark a port as trusted

- `Switch(config)# interface <type><number>`
- `Switch(config-if)# ip dhcp snooping trust`

(Optional) Set rate limits to prevent DHCP starvation attacks

- `Switch(config-if)# ip dhcp snooping limit rate <requests per second>`

Display DHCP snooping status

- `Switch# show ip dhcp snooping`

Display the binding table

- `Switch# show ip dhcp snooping binding`



Binding Table Example

Switch# show ip dhcp snooping binding

MacAddress	IpAddress	Lease(sec)	Type	VLAN	Interface
00:1A:2B:3C:4D:5E	192.168.10.20	86000	dhcp-snooping	10	Gi0/2
00:1B:3C:4D:5E:6F	192.168.10.21	86000	dhcp-snooping	10	Gi0/3



DHCP Snooping Example

```
Switch(config)# ip dhcp snooping
```

```
Switch(config)# ip dhcp snooping vlan 10
```

```
Switch(config)# interface GigabitEthernet0/1
```

```
Switch(config-if)# ip dhcp snooping trust
```

```
Switch(config-if)# ip dhcp snooping limit rate 10
```



DHCP Snooping Commands

Command	Description
<code>ip dhcp snooping</code>	Enable DHCP snooping globally
<code>ip dhcp snooping vlan <vlan-id></code> <code>ip dhcp snooping vlan 10</code>	Enable DHCP snooping on a specific VLAN
<code>ip dhcp snooping trust</code>	Mark a port as trusted
<code>ip dhcp snooping limit rate</code> <code><requests per second></code>	(Optional) Limit DHCP request rate per second Requests exceeding this number are dropped
<code>show ip dhcp snooping</code>	Display DHCP snooping status
<code>show ip dhcp snooping binding</code>	Display the binding table

8.10 Dynamic ARP Inspection (DAI)

CCNA 200-301 v1.1

Module 8

What is DAI?

Configuring DAI

What is DAI?

Prevents ARP spoofing (also called ARP poisoning) by intercepting and verifying ARP packets

Works in conjunction with DHCP snooping

Ensures that only valid ARP requests and responses (based on trusted bindings) are forwarded by the switch



Configuring DAI

Ensure DHCP snooping is enabled

Enable Dynamic ARP Inspection for the desired VLAN

- `Switch(config)# ip arp inspection vlan <number>`

Configure Trusted Interfaces for ARP Inspection

- `Switch(config)# interface <type><number>`
- `Switch(config-if)# ip arp inspection trust`
- `Switch(config-if)# exit`

Optional: Configure Rate Limiting for Untrusted Ports

- Protect against DoS attacks
- `Switch(config)# interface <type><number>`
- `Switch(config-if)# ip arp inspection limit rate 30`



Verify DAI

Check DAI status for VLANs

- Switch# show ip arp inspection

Check the DHCP snooping binding table

- Switch# show ip dhcp snooping binding

Check ARP packet statistics

- Switch# show ip arp inspection statistics

VLAN	Configuration	Operation	ACL Match	Static ACL	DHCP Snooping
----	-----	-----	-----	-----	-----
10	Enabled	Active	No	No	Yes



DAI Example

```
Switch(config)# ip dhcp snooping
```

```
Switch(config)# ip dhcp snooping vlan 10
```

```
Switch(config)# interface GigabitEthernet0/1
```

```
Switch(config-if)# ip dhcp snooping trust
```

```
Switch(config)# ip arp inspection vlan 10
```

```
Switch(config)# interface GigabitEthernet0/1
```

```
Switch(config-if)# ip arp inspection trust
```

```
Switch(config)# interface GigabitEthernet0/2
```

```
Switch(config-if)# ip arp inspection limit rate 30
```



DAI Commands

Command	Description
<code>ip arp inspection vlan <number></code> <code>ip arp inspection vlan 10</code>	Global: Enable Dynamic ARP Inspection for the VLAN
<code>ip arp inspection trust</code>	Interface: Configure a trusted interface for DAI
<code>ip arp inspection limit rate 30</code>	Interface: Configure Rate Limiting for Untrusted Ports
<code>show ip arp inspection</code>	Check DAI status for VLANs
<code>show ip dhcp snooping binding</code>	Check the DHCP snooping binding table
<code>show ip arp inspection statistics</code>	Check ARP packet statistics

8.11 Layer 2 Port Security

CCNA 200-301 v1.1

Module 8

What is Port Security?

Configuring Port Security

Port Security Violation Modes

What is Port Security?

The ability to limit traffic entering Layer 2 switchports

You can set port security to:

Limit the # of MAC addresses that are allowed on a port

Specify which MAC addresses are allowed on that port

- Allow the switch to add the first address it sees as the permitted MAC

Specify the action if there is a security violation on the port

For switchports that have both Voice and Data VLANs:

- Ensure that TWO MAC addresses are permitted on the port
- Configure the port for both VLANs:
 - `Switch(config-if)# switchport access vlan <number>`
 - `Switch(config-if)# switchport voice vlan <number>`



Configuring Port Security

Port security can only be configured on access ports

- `Switch(config-if)# switchport port-security`

MAC address limiting

- Restrict how many MAC addresses are allowed on that port
- `Switch(config-if)# switchport port-security maximum [number]`

Static MAC

- Manually associate a MAC (and only that MAC) on a port
- `Switch(config-if)# switchport port-security mac-address [mac-address]`

Sticky MAC

- First dynamically learned MAC address becomes the authorized MAC for that port
- Saved in running-config / retained even after a reboot
- `switchport port-security mac-address sticky`



Port Security Violation Modes

You can set the Violation Mode to determine what the switch will do

- `Switch(config-if)# switchport port-security violation [protect | restrict | shutdown]`

Shutdown

- The default mode
- The port is immediately put into the error-disabled state, effectively shutting it down
- Port must be manually re-enabled or configured to automatically recover after a certain period

Protect

- Discards frames with unauthorized MAC addresses
- Does not generate a security notification or disable the port

Restrict

- Discards frames with unauthorized MAC addresses
- Increments the security violation counter
- Generates a log message or SNMP trap
- Does not disable the port



Port Security Commands

Configuration	Description
<code>switchport port-security</code>	Enable port security on a specific interface
<code>switchport port-security maximum [number]</code> <code>switchport port-security maximum 2</code>	Set the maximum number of allowed MAC addresses on a port
<code>switchport port-security mac-address [mac-address]</code> <code>switchport port-security mac-address 0001.2345.6789</code>	Manually specify the MAC address that is allowed in the interface
<code>switchport port-security mac-address sticky</code>	• Add the first MAC address heard on the port as the authorized MAC • Save in running config
<code>switchport port-security violation [protect restrict shutdown]</code> <code>switchport port-security violation protect</code>	• Specify the violation response • Default is shutdown



Port Security Verification Commands

Command	Description
<code>show port-security</code>	Display an overview of port security status for all switchports
<code>show port-security interface <type><number></code>	Display detailed port security settings for a specific interface
<code>show port-security address</code>	Display secure MAC addresses (learned or static) on the switch
<code>show port-security interface <type><number></code>	Determine if a specific port has been disabled due to a security violation
<code>show port-security violation</code>	Display a summary of all security violations that have occurred
<code>show mac address-table secure</code>	Display MAC addresses (dynamic and static) that are currently secured on the switch
<code>show running-config interface <type><number></code>	Display the current configuration of a specific interface, including any port security settings that have been applied



Data and Voice Port Security Commands

Configuration	Description
<pre>switchport voice vlan [vlan ID] switchport voice vlan 7</pre>	Configure the switch access port with the voice VLAN ID
<pre>switchport port-security maximum [number] switchport port-security maximum 2</pre>	Limit the number of allowed MAC addresses on the switchport
<pre>switchport port-security violation [protect restrict shutdown] switchport port-security violation protect</pre>	Set the violation response on the switchport

8.12

Authentication, Authorization and Accounting (AAA)

CCNA 200-301 v1.1

Module 8

What is AAA?

RADIUS

TACACS+

802.1x

What is AAA?

A framework used to control access to network resources, enforce policies, and track user activities in a network environment

- Verifies identity and controls resource access
- Ensures that only authorized users can access resources
- Activities are monitored for security and compliance purposes

Authentication

- Verify the identity of a user, device, or entity trying to access the network
- Ensure that the person or device is who they claim to be
- Passwords, digital certificates, biometrics, smart cards, and multi-factor authentication (MFA)

Authorization

- Determines what an authenticated user or device is allowed to do on the network
- Involves granting or denying access to network resources based on predefined policies

Accounting

- Tracks and records the activities of users and devices on the network
- Used for monitoring, auditing, and compliance purposes



RADIUS

Remote Authentication Dial-In User Service

A protocol that provides centralized AAA services for users accessing a network

- Clear-text communications
- UDP 1812

RADIUS Server

- The central AAA server that performs the authentication

RADIUS Client

- A switch, WAP, firewall, VPN server, etc. that puts the supplicant on hold while the user authenticates
- Uses a shared secret to authenticate to the RADIUS server

Supplicant

- An end-user device such as a laptop or phone that is trying to make the connection

802.1x

- Allows the RADIUS client to prevent the supplicant from entering the network until the user authenticates
- Can use a wide variety of authentication including simple passwords, certificates, tokens, biometrics, etc.



TACACS+

Terminal Access Controller Access-Control System Plus

Cisco-proprietary AAA service

Separates authentication, authorization, and accounting for more flexibility

Logging and permissions are more granular

All communications are encrypted

TCP 49

For information on how to implement AAA in a Cisco environment see:

<https://www.cisco.com/c/en/us/support/docs/security-vpn/terminal-access-controller-access-control-system-tacacs-/10384-security.html>



802.1x

An IEEE standard for port-based network access control

Defines a framework for authenticating devices attempting to connect to a LAN or WLAN

- Ensures that only authorized users can access network resources

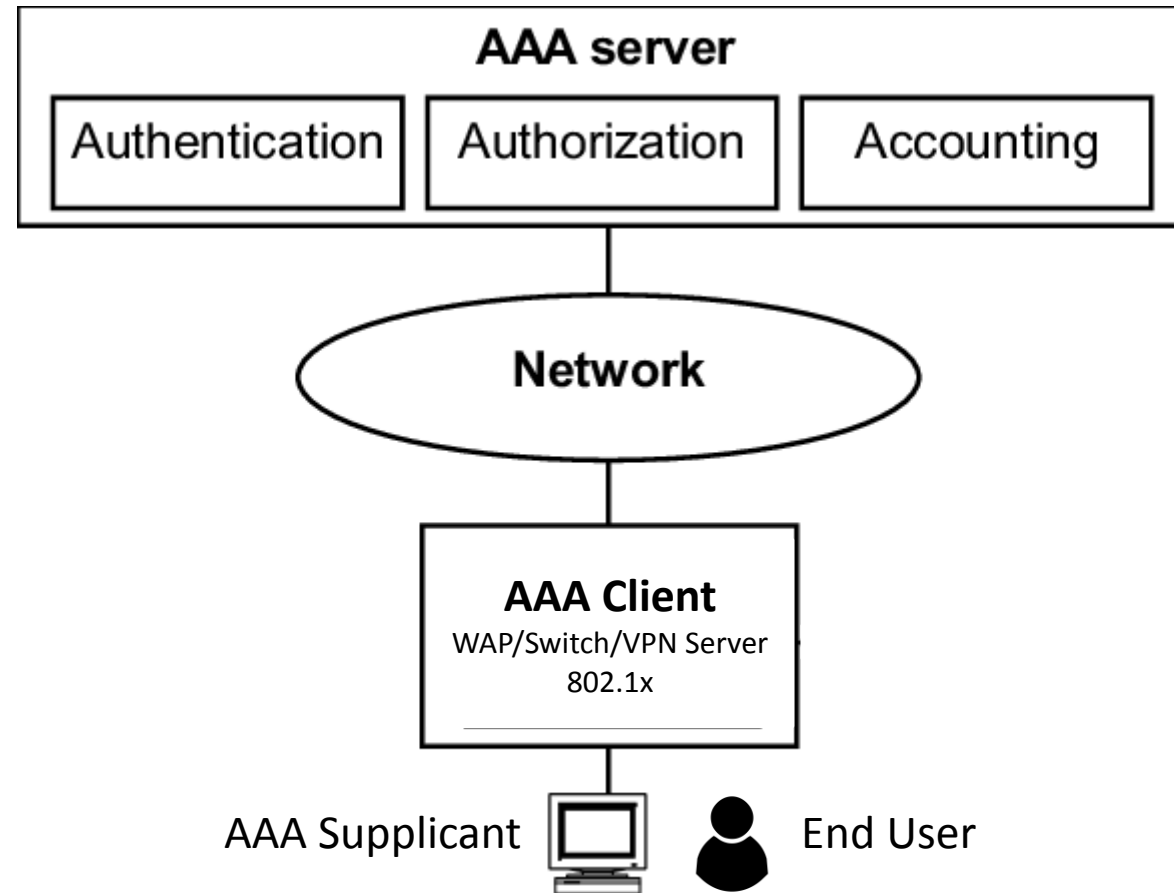
Typically incorporated in RADIUS and TACACS+ AAA implementations'

- User traffic cannot move past the authenticating network device (switch, WAP, VPN server) until the user or device successfully authenticates

Uses authentication protocols such as Extensible Authentication Protocol (EAP) to handle the actual authentication



AAA Architecture Example



8.13 Wireless Security

CCNA 200-301 v1.1

Module 8

Wireless Security Protocols

WPA2 PSK WLAN Configuration

Wireless Security Protocols

Feature	WPA	WPA2	WPA3
Encryption	TKIP	AES (CCMP) 128-bit key	AES (CCMP) 192-bit key
Authentication	Pre-shared key (PSK) Enterprise (802.1x + RADIUS)	PSK, Enterprise	Simultaneous Authentication of Equals (SAE) replaces PSK, Enterprise
Key Management	TKIP – each packet has a new key	Robust Security Network (AES CCMP) key management	Forward Secrecy New key every session
Protection Against	Weak WEP keys, anti-replay packet sequencing	TKIP vulnerabilities, stronger	Brute-force attacks, offline dictionary attacks
Introduced In	2003	2004	2018
Use Case	Legacy devices	Commonly used today	High security environment



WPA2 PSK WLAN Configuration



WLANs

WLANs > Edit 'Student'

< BACK Apply

General Security QoS Policy-Mapping Advanced

Layer 2 Layer 3 AAA Servers

Layer 2 Security **WPA+WPA2** ☐ MAC Filtering ☐

Fast Transition

Fast Transition ☐

Protected Management Frame

PMF Disabled

WPA+WPA2 Parameters

WPA Policy ☐

WPA2 Policy ☒

WPA2 Encryption ☒ AES ☐ TKIP

Authentication Key Management

802.1X ☐ Enable

CCKM ☐ Enable

PSK ☒ Enable

WLANs

WLANs > Edit 'Student'

<

General Security QoS Policy-Mapping Advanced

Layer 2 Layer 3 AAA Servers

Layer 2 Security **WPA+WPA2** ☐ MAC Filtering ☐

Protected Management Frame

PMF Disabled

WPA+WPA2 Parameters

WPA Policy ☐

WPA2 Policy ☒

WPA2 Encryption ☒ AES ☐ TKIP

Authentication Key Management

802.1X ☐ Enable

CCKM ☐ Enable

PSK ☒ Enable

FT 802.1X ☐ Enable

FT PSK ☐ Enable

PSK Format ASCII

.....

WPA+WPA2 Parameters

WPA Policy ☐

WPA2 Policy ☒

WPA2 Encryption ☒ AES ☐ TKIP

Authentication Key Management

802.1X ☐ Enable

CCKM ☐ Enable

PSK ☒ Enable

FT 802.1X ☐ Enable

FT PSK ☐ Enable

PSK Format ASCII

.....



Review

8.14 Review

CCNA 200-301 v1.1

Module 8

Review

A threat is anything that can potentially violate the security of a system or organization

An exploit is the actual mechanism for taking advantage of a vulnerability

A payload is the part of an exploit that actually damages the system or steals information

A compromise is unauthorized access, control of, or damage to a computer system, network, or data

A zero-day attack is an attack that occurs before a vendor is aware of a flaw or is able to provide a patch for that flaw

A mitigation is any administrative, physical or technical countermeasure to reduce the risk of compromise, or reduce the damage in case of compromise



Review (cont'd)

A good security program should include the following components:

Information Security Policies

- Acceptable Use Policy, Password Policy, Remote Access Policy, Access Control Policy, etc.

Data protection and privacy

Physical security

Security baselines

- Minimum standards for different device, application, and data types

Access control and identity management

Network security

- Security zones, firewalls, IDS/IPS, VPNs, network segmentation (VLANs)



Review (cont'd)

A good security program should include the following components (cont'd):

Endpoint security

Vulnerability management

- Patching and updates

Logging, monitoring, auditing

Third-party vendor management

End-user training and awareness

Incident response (disaster recovery, business continuity)



Review (cont'd)

Local device security measures include:

Creating an enable secret

Requiring users to authenticate

Implementing centralized authentication with AAA and MFA

Requiring authentication for console and VTY access

Using SSH instead of telnet

Disabling unused services and ports such as HTTP or SNMP



Review (cont'd)

Local device security measures include (cont'd):

Creating banner messages for legal notices

Regularly auditing logs

- Configure syslog to monitor for unauthorized access
- Use AAA to track access

Disabling password recovery to prevent unauthorized physical access to the device

Providing physical security

Encrypting and securely storing device backups



Review (cont'd)

A banner is a message displayed to users when they log in to a Cisco device

Can be used to display legal warnings, notices, or information to users

Banners can be a message of the day (MOTD) banner, a login banner, or an EXEC banner



Review (cont'd)

In local authentication:

Users are authenticated against the device itself

Username and password are stored in the running / startup configuration file(s)

The local devices does not forward authentication to a AAA server

Auto secure is a wizard that automates security best practices on the router



Review (cont'd)

The **enable** command moves you from unprivileged USER EXEC mode to privileged mode

Type 7 encryption is very weak and easily cracked

Use the enable secret command to put a password on the enable command and store it as a Type 5 MD5 hash

If both an enable password and an enable secret are configured, users will be required to enter the enable secret

- They will only be able to use the enable password if the enable secret is deleted from configuration



Review (cont'd)

You can implement strong password policies on Cisco device

- Enforce minimum password length and complexity with security passwords

Password policy best practices include:

- Avoiding clear-text or Type 7 (weak) password encryption
- Using stronger hashes like Type 5 (MD5) or Type 9 (scrypt) where available

The **service password-encryption** command encrypts existing and future passwords as Type 7

- It does not change passwords stored as Type 5 or Type 9



Review (cont'd)

Multi-factor authentication (MFA) uses 2 or more “factors” to authenticate a person:

- Something you know (password / PIN)
- Something you have (certificate, smart card, token, one-time passcode sent to email or phone)
- Something you are (biometrics)

You can implement MFA by integrating Cisco devices with TACACS+ or RADIUS AAA



Review (cont'd)

When you create a local user account on a device, you specify the name, privilege level, and password for that user

Type 7 encryption

- Will encrypt and store the password using Cisco 7 encryption – easily cracked
- Use keyword “password” followed by 0 or 7
- 0 = An unencrypted version of the password will follow
- 7 = A Cisco 7 encrypted version of the password will follow – will store the encrypted password as entered

Type 5 MD5 hash

- Will store the password as an MD5 hash with 32-bit salt
- Use keyword “secret” followed by 0 or 5
- 0 = An unencrypted version of the password will follow
- 5 = An MD5 hash (with salt) of the password will follow – will store the hash as entered



Review (cont'd)

Use password recovery when privileged account passwords to the device have been forgotten or lost

Requires physical access to the device

You boot the device into ROMMON mode and temporarily change the configuration register

Can be disabled with the global command **no service password-recovery**



Review (cont'd)

Remote access is the ability to access a system or network, whether it's a personal device or office server, without being physically present

Typically accomplished through a VPN connection

IPSEC is the most common type of VPN

- Used for Remote Access and Site-to-site VPNs



Review (cont'd)

IPSEC consists of two protocols:

- Authentication Header (AH)
- Encapsulating Security Payload (ESP)

You can use one or both of these protocols as desired

- Most implementations just use ESP

Has two modes:

- Tunnel
- Transport

Uses ISAKMP and IKE to negotiate the session

- Securely exchange public keys
- Agree on how traffic will be encrypted and decrypted



Review (cont'd)

AH validates the integrity and authenticity of the packet

- Calculates an HMAC hash over the payload and (most of the) IP header
- HMAC-SHA-512 / 384 / 256, HMAC-SHA-1 (legacy), HMAC-MD5 (legacy)

Does not encrypt the payload

Cannot tolerate network address translation (NAT)

- Translation of the Layer 3 header breaks the hash

When used with ESP, adds an extra layer of security



Review (cont'd)

Encapsulating Security Payload (ESP) encrypts and validates the integrity of the payload

ESP does not modify the Layer 3 header

ESP is the most common implementation of site-to-site IPSEC VPNs

When implemented as NAT/T, the entire ESP packet becomes a payload of an additional UDP header

This allows the ESP VPN to go through network address translation without any problems

ISAKMP and IKE are used by IPSEC to form a VPN between two peer devices



Review (cont'd)

ISAKMP defines the policy and cryptographic parameters for creating a security association (SA) between VPN peers

Internet Key Exchange (IKE) uses ISAKMP and the Diffie-Hellman algorithm to exchange keys and negotiate and establish secure communications



Review (cont'd)

IPSEC Transport Mode is used to create host-to-host VPNs

Packets are not encapsulated inside another IP packet

Two hosts create a VPN directly between them

Hosts have to be able to route traffic to each other

Typically used for client-server or server-server connections



Review (cont'd)

IPSEC Tunnel Mode is used to create site-to-site VPNs

Packets ARE encapsulated inside another IP packet

- Typically a private IP packet is hidden inside a public IP packet

Two edge devices (routers, firewalls) create a VPN between them

- Usually over the Internet

Client traffic between the two networks flows through the VPN

- Client traffic is only encrypted when in the tunnel
- Clients are unaware that the connection is a VPN
- Allows subnets with private IP addresses to connect to each other
- You must just make sure that there is no IP address overlap between the sites



Review (cont'd)

An Access Control List (ACL) is a set of rules used to control traffic in and out of a firewall, router, or multilayer switch

Can be used for:

- Packet filtering, defining a range of source addresses for NAT, defining interesting traffic for a VPN, QoS traffic prioritization, controlling access to VTY lines (Telnet/SSH Access), and more

Each packet is compared to the rules in the ACL and processed accordingly

Depending on the ACL type, rules will include:

- Access-list number or name
- Action (permit or deny)
- Protocol (IP, ICMP, IGMP, TCP, UDP and others)
- Source IP address
- Destination IP address
- Source port
- Destination port



Review (cont'd)

A standard ACL filters traffic based on source IP address only

Typically applied near the destination to avoid unintended filtering of traffic

Uses numbers between 1-99 (and expanded range 1300-1999)



Review (cont'd)

An extended ACL filters traffic based on multiple criteria:

- Protocol type (IP, TCP, UDP, ICMP, etc.)
- Source and destination IP addresses
- Source and destination port
 - For common ports, you can specify the Layer 7 protocol instead
- Other parameters (such as TCP flags, ICMP types)

Typically applied near the source

Uses numbers from:

- 100-199 (Standard extended ACL number range)
- 2000-2699 (Expanded extended ACL number range)



Review (cont'd)

You can give either a standard or extended ACL a name in place of a number

ACL rules are read from the top down

- Each packet is evaluated against the rule set

If a match is found at a rule, the specified permit or deny is applied

- No other rules are checked
- The packet is through being evaluated

At the end of any ACL is an implicit “deny all” statement

If you create an ACL with only deny statements, be sure to add some type of permit statement at the end to allow some traffic to pass through

An ACL's rule order cannot be changed without re-creating the entire ACL

Once you create the ACL, you apply it to a router interface, either inbound or outbound



Review (cont'd)

As a best practice, create your ACL in a text editor before entering in the CLI

Also, create a diagram with IP addresses, ACL rules, and arrows representing desired traffic flow

Use the diagram as a reference to create and troubleshoot ACLs



Review (cont'd)

DHCP snooping helps to prevent malicious or rogue DHCP servers from providing incorrect IP address information to clients within the network

Works by creating a database of IP addresses that have been assigned by the legitimate DHCP server

Blocks any DHCP responses from unauthorized or rogue servers

Blocks traffic of any device that spoofed its IP or did not receive a lease from a legitimate DHCP server



Review (cont'd)

Dynamic ARP Inspection (DAI) works with DHCP snooping to prevent ARP spoofing

It intercepts and verifies ARP packets to ensure that only valid ARP requests and responses (based on trusted bindings) are forwarded by the switch



Review (cont'd)

Port security is the ability to limit traffic entering Layer 2 switchports

You can set port security to:

- Limit the # of MAC addresses that are allowed on a port
- Specify which MAC addresses are allowed on that port
- Allow the switch to add the first address it sees as the permitted MAC
- Specify the action if there is a security violation on the port



Review (cont'd)

You can configure any of three responses to a port violation:

Shutdown

- The default mode
- The port is immediately put into the error-disabled state, effectively shutting it down
- Port must be manually re-enabled or configured to automatically recover after a certain period

Protect

- Discards frames with unauthorized MAC addresses
- Does not generate a security notification or disable the port

Restrict

- Discards frames with unauthorized MAC addresses
- Increments the security violation counter
- Generates a log message or SNMP trap
- Does not disable the port



Review (cont'd)

Authentication, Authorization and Accounting (AAA) is a framework for controlling access to network resources, enforcing policies, and tracking user activities in a network environment

Remote Authentication Dial-In User Service (RADIUS) is a protocol that provides centralized AAA services for users accessing a network

- Vendor-neutral
- Clear-text communications
- UDP 1812

A RADIUS Server is a central AAA server that performs the authentication

A RADIUS Client is a switch, WAP, firewall, VPN server, etc. that puts a supplicant on hold while the user authenticates

- The RADIUS client authenticates to the RADIUS server using a shared secret

A supplicant is an end-user device such as a laptop or phone that is trying to make the connection

802.1x is a standard that allows the RADIUS client to prevent the supplicant from entering the network until the user authenticates

- Can use a wide variety of authentication including simple passwords, certificates, tokens, biometrics, etc.



Review (cont'd)

TACACS+ is a Cisco-proprietary AAA service

It separates authentication, authorization, and accounting for more flexibility

Logging and permissions are more granular

All communications are encrypted over TCP 49



Review (cont'd)

Wi-Fi has three security standards that you can choose from

WPA introduced TKIP key rotation to address the security weaknesses of WEP

- Weak by today's standards
- Only use for legacy compatibility

WPA2 introduced AES CCMP 128-bit (much stronger) encryption

- Includes data integrity and authenticity checks
- Most commonly used today

WPA3 introduced (Perfect) Forward Secrecy

- Uses the Simultaneous Authentication of Equals (SAE) handshake to replace pre-shared key
- Fresh key every session
- Key derived from Diffie-Hellman key exchange
- Even with the network password, an attacker cannot retroactively decrypt previous communications
- AES CCMP encryption increased to 192-bit



Review (cont'd)

You can configure a pre-shared key on a WAP to authenticate users

In enterprise environments, WAPs are typically configured as RADIUS clients

- They place the supplicant mobile device “on hold” as they forward user credentials to a central RADIUS server

You can use a Cisco Wireless LAN Controller (WLC) to set security levels on their WAPs

- WPA/WPA2 pre-shared key
- AAA server

